

PROJECT 7 OF 8 — PART 1: INCIDENT DEEP DIVE
EQUIFAX DATA BREACH (2017)*Unpatched CVE · 147 Million SSNs Stolen · 76 Days Silent · \$575M Settlement*

 **THIS PROJECT:** Understand what happened, map the attack, research the CVE. This project ends with a CVE Research Worksheet (50 points).

 **CVE / ADVISORY:** CVE-2017-5638 (Apache Struts 2 RCE, CVSS 10.0 CRITICAL) — nvd.nist.gov/vuln/detail/CVE-2017-5638

INCIDENT OVERVIEW

From May 13 to July 30, 2017, attackers exploited CVE-2017-5638, a known, publicly patched vulnerability in Apache Struts web framework, to breach Equifax — one of the three largest credit reporting agencies in the United States. The patch had been available for 69 days before Equifax was compromised. Over 76 days, attackers ran ~9,000 queries against 48 different Equifax databases, exfiltrating 147 million Social Security numbers, birthdates, addresses, and driver's license numbers. An expired SSL certificate on Equifax's traffic inspection tool meant malicious traffic went uninspected for 19 months. Settlement: \$575 million.

KEY FACTS AT A GLANCE

- CVE-2017-5638 patch was available 69 days before Equifax was breached — this was 100% preventable
- 147.9 million Social Security Numbers exposed — nearly half the U.S. adult population
- Also stolen: birth dates, addresses, driver's license numbers, 209,000 credit card numbers
- ~9,000 database queries run during the 76-day breach against 48 different databases
- Expired SSL inspection certificate — encrypted malicious traffic went uninspected for 19 months
- \$575M FTC settlement — largest data breach settlement in history at the time
- CEO Richard Smith resigned September 2017; three executives investigated for insider trading

PROJECT 7 · DAY 1**MONDAY — INCIDENT INTRODUCTION + CIA TRIAD****1-2 HRS**

 **OBJECTIVE:** Students understand the Equifax Data Breach at a high level and apply the CIA Triad to identify which pillars were violated and how.

PROJECT 7 · DAY 2**TUESDAY — CYBER KILL CHAIN — ALL 7 PHASES****1-2 HRS**

 **OBJECTIVE:** Students map the complete attack through all 7 Kill Chain phases using specific incident evidence.

PROJECT 7 · DAY 3**WEDNESDAY — MITRE ATT&CK — HANDS-ON LAB****1-2 HRS**

 **OBJECTIVE:** Students identify specific ATT&CK techniques, navigate attack.mitre.org, and explain each technique in plain English.

PROJECT 7 · DAY 4**THURSDAY — CVE RESEARCH LAB + WORKSHEET
SUBMISSION (50 PTS)****1-2 HRS**

 **OBJECTIVE:** Students research the CVE or CISA advisory, build the incident timeline, finalize and submit the CVE Research Worksheet.

 **DUE:** Thursday of this project. Submit to your instructor.

[10 pts] What is the CVE number and CVSS score for this incident? If no CVE exists, what CISA advisory or identifier applies? What does the CVSS score (or the absence of a CVE) tell you about the nature of this vulnerability?

[10 pts] Describe the vulnerability or weakness in your own words — plain English, no jargon. A non-technical reader should completely understand what went wrong.

[10 pts] When was the official patch or fix released? How much time passed between the fix being available and the breach occurring? What does that timeline tell you about the organization's security practices?

[10 pts] Who was involved in containing this incident? What specific actions were taken? How long did full containment take?

[10 pts] List your 3 most critical "From Here On Out" recommendations for any organization that uses similar technology. For each, explain specifically WHY it would have prevented or reduced this breach.

REFERENCES & RESOURCES

- nvd.nist.gov/vuln/detail/CVE-2017-5638 — full technical details, CVSS score, references
- U.S. House of Representatives Report: "The Equifax Data Breach" (December 2018) — oversight.house.gov
- FTC: "Equifax to Pay \$575 Million" — ftc.gov (July 22, 2019)
- Apache Security Bulletin S2-045 — struts.apache.org/security/security-bulletins
- CISA Known Exploited Vulnerabilities Catalog: cisa.gov/known-exploited-vulnerabilities-catalog
- MITRE ATT&CK: attack.mitre.org — search T1190, T1059, T1048